

Project title:

Integration of Zscaler with Identity Providers for Secure Authentication and Authorization

Group members:

S no	Name	college	contact
1	Santhosh R	Nandha arts and science college	santhosh25.4.2006@gmail.com
2	Mogith C	Nandha arts and science college	mogithmonisha@gmail.com
3	Pragadheeswaran D	Nandha arts and science college	Pragadheeswaran0905@gmail.com
4	Mithun P	Nandha arts and science college	Mithundevi090@gmail.com
5	Mohammed Ushmankani A	Nandha arts and science college	Ushmanabdul828@gmail.com

1. Introduction

Modern organizations rely heavily on cloud applications and remote access to perform daily operations. Traditional network security models based on perimeter defense and VPN access are no longer sufficient because they provide excessive access to internal networks once authentication is completed.

This project focuses on integrating the Zscaler Zero Trust platform with enterprise Identity Providers (IdPs) such as:

- **Microsoft Entra ID (Azure AD)**
- **Okta**
- **Active Directory**

The objective is to create a secure authentication and authorization framework using modern protocols such as SAML, OIDC, and SCIM.

By integrating these identity providers with Zscaler, organizations can implement Single Sign-On (SSO), enforce Multi-Factor Authentication (MFA), and support Zero Trust security architecture.

2. Abstract

This project explains how the Zscaler Internet Access and Zscaler Private Access platforms can be integrated with enterprise identity providers to enable centralized authentication and access control.

The integration allows organizations to:

- **Implement Single Sign-On (SSO)**
- **Enforce Multi-Factor Authentication (MFA)**
- **Enable automated user provisioning**
- **Improve security visibility and auditing**

The system uses identity standards such as:

- **SAML (Security Assertion Markup Language)**
- **OIDC (OpenID Connect)**

- **SCIM (System for Cross-domain Identity Management)**

These technologies allow user authentication to occur through trusted corporate directories instead of local application credentials.

As a result, the organization achieves a Zero Trust architecture where access decisions depend on identity, context, and security policies rather than network location.

3. Objectives of the Project

The main objectives of this project are:

- 1. Integrate Zscaler with enterprise identity providers.**
 - 2. Implement secure authentication mechanisms using SSO and MFA.**
 - 3. Replace traditional VPN-based access models.**
 - 4. Reduce security risks such as lateral movement and unauthorized access.**
 - 5. Automate user provisioning and lifecycle management.**
 - 6. Improve overall security monitoring and compliance.**
-

4. Use Case Scenarios

4.1 Remote Faculty Access to Research Data

A faculty member working remotely needs access to internal research servers.

Security Output

- **Identity verified through IdP.**
- **MFA required.**

- **Access limited to research server.**
 - **No access to other internal systems.**
-

4.2 Student Access to Library Resources

Students require off-campus access to academic databases.

Security Output

- **User identity verified.**
 - **Access limited to library portal.**
 - **SSO authentication.**
 - **No network-level access.**
-

4.3 HR Administrator Access to Payroll System

HR staff access payroll data which contains sensitive information.

Security Controls

- **Identity verification**
 - **Time-based access restrictions**
 - **Multi-Factor Authentication**
 - **Full session logging**
-

4.4 IT Helpdesk Remote Troubleshooting

IT technicians require temporary administrative access to specific servers.

Security Output

- **Just-in-time access granted**

- **Privileges expire after session**
 - **Activity logging enabled**
-

4.5 Contractor Access to Project Tools

External contractors require access to specific collaboration tools.

Security Output

- **Limited application access**
 - **Automatic account expiration**
 - **Network segmentation**
-

Stage 1

Title : Top 10 vulnerabilities

Web applications are a fundamental part of modern digital systems and are widely used in industries such as banking, healthcare, education, e-commerce, and government services. These applications allow users to interact with servers through web browsers and perform various activities such as data entry, financial transactions, communication, and information retrieval. Because web applications often handle sensitive data and provide access to critical systems, ensuring their security is extremely important. However, many web applications contain security weaknesses that attackers can exploit if they are not properly designed, implemented, and maintained.

Security weaknesses in web applications can lead to serious consequences. Attackers may exploit these flaws to gain unauthorized access to systems, steal confidential information, manipulate data, or disrupt services. For example, poorly validated input fields may allow attackers to inject malicious code, while improper authentication

No Vulnerability

CWE

mechanisms may enable unauthorized users to access restricted resources. Such vulnerabilities can compromise the confidentiality, integrity, and availability of an application, which are the three fundamental principles of information security.

To systematically identify and categorize these weaknesses, security researchers and organizations use the Common Weakness Enumeration (CWE) framework. CWE is a comprehensive list of standardized identifiers for common software and hardware security weaknesses. It is maintained by the MITRE Corporation and serves as a valuable reference for developers, security analysts, and researchers. Each weakness listed in CWE is assigned a unique identifier (CWE ID) along with a description explaining the nature of the vulnerability and how it may occur in software systems.

1	Improper File Path Sanitization	CWE-284
2	Invalid Certificate	CWE-295
3	Missing X-Frame-Options Header	CWE-1021
4	Missing X-Content-Type Header	CWE-16
5	Drupal API Vulnerability	CWE-20
6	Cross-Site Scripting (XSS)	CWE-79
7	Denial of Service	CWE-400
8	TLS 1.0 Detection	CWE-

327

**CWE-
497**

9 web.config Disclosure

**10 Cross-Site Request Forgery (CSRF) CWE-
352**

Vulnerability Assessment Report

1. Improper File Path Sanitization

CWE Number: CWE-22 – Path Traversal

OWASP Category: A01:2021 – Broken Access Control

Description:

Improper file path sanitization occurs when an application fails to properly validate or restrict user-supplied file paths. Attackers may manipulate file paths to access restricted files or directories on the server.

Business Impact:

This vulnerability may allow attackers to read sensitive files such as configuration files, system files, or application source code. Exposure

of such information can lead to further attacks and compromise of the system.

The screenshot shows the MITRE Common Weakness Enumeration (CWE) website. The browser address bar displays 'cwe.mitre.org/data/definitions/22.html'. The page title is 'CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') (4.19.1)'. The page includes a navigation bar with links like Home, About, Learn, Access Content, Community, and Search. The main content area features the title 'CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')' and a description: 'The product uses external input to construct a pathname that is intended to identify a file or directory that is located underneath a restricted parent directory, but the product does not properly neutralize special elements within the pathname that can cause the pathname to resolve to a location that is outside of the restricted directory.' A diagram illustrates the vulnerability: 'Input Data' leads to a 'Vulnerable' box, which then leads to a 'Vulnerable Product Fails to Neutralize Input Data' box. This box points to a 'File System' box, which contains a green box labeled 'Access Allowed' and a red box labeled 'Not Supposed to Access'. A red arrow points from the 'Access Allowed' box to the 'Not Supposed to Access' box, indicating an unauthorized access. The page also includes a 'Vulnerability Mapping' section with 'ALLOWED (with careful review of mapping notes)' and 'Abstraction: Base'.

2. Invalid SSL/TLS Certificate

CWE Number: CWE-295 – Improper Certificate Validation

OWASP Category: A02:2021 – Cryptographic Failures

Description:

An invalid or improperly validated SSL/TLS certificate may allow attackers to intercept encrypted communication between the client and server. This can lead to man-in-the-middle attacks.

Business Impact:

Sensitive information such as login credentials, personal data, or financial information can be intercepted by attackers, resulting in data breaches and loss of user trust.

The screenshot shows the MITRE CWE website page for CWE-295: Improper Certificate Validation (4.19.1). The page includes a navigation bar with links like Home, About, Learn, Access Content, Community, and Search. The main content area displays the weakness ID, vulnerability mapping (ALLOWED), and abstraction (Base). It also features a description of the weakness and a table of common consequences, including 'Bypass Protection Mechanism; Gain Privileges or Assume Identity' and 'Scope: Integrity, Authentication'.

3. Missing X-Frame-Options Header

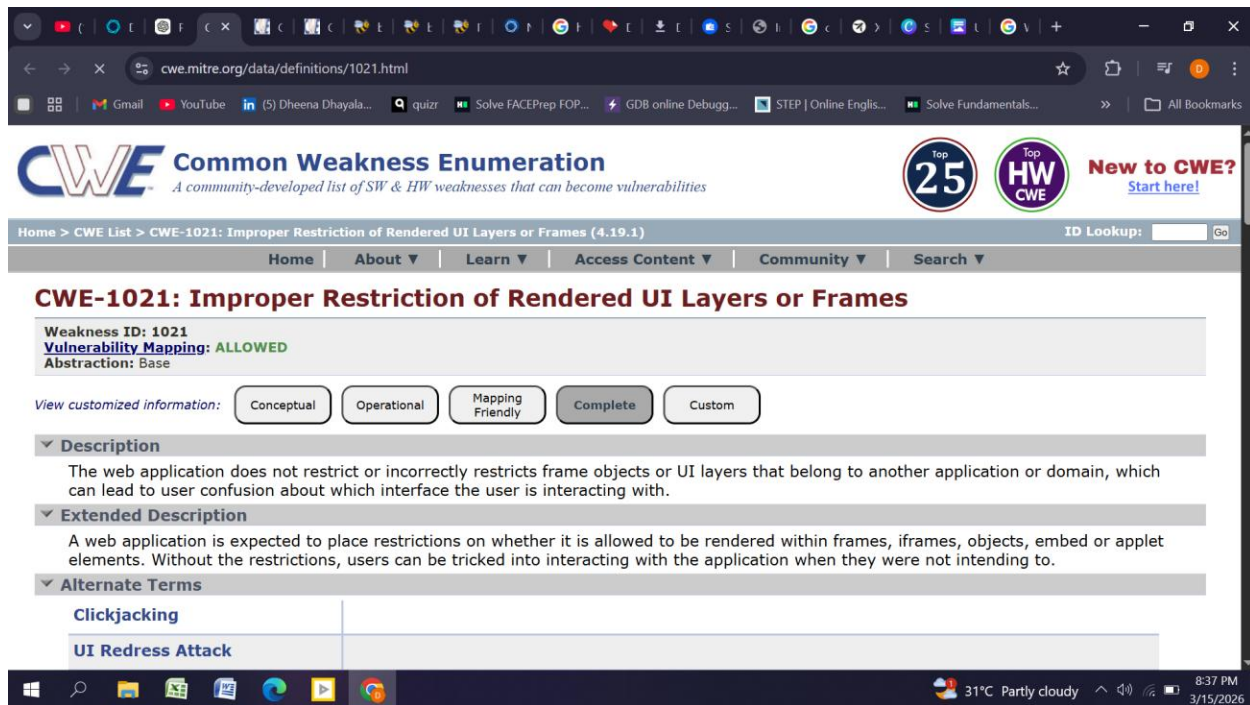
CWE Number: CWE-1021 – Improper Restriction of Rendered UI Layers
OWASP Category: A05:2021 – Security Misconfiguration

Description:

The X-Frame-Options header prevents a webpage from being embedded inside frames or iframes on other websites. If this header is missing, attackers can perform clickjacking attacks.

Business Impact:

Attackers may trick users into clicking hidden buttons or performing unintended actions such as transferring funds or changing account settings.



4. Missing X-Content-Type-Options Header

CWE Number: CWE-16 – Configuration

OWASP Category: A05:2021 – Security Misconfiguration

Description:

The X-Content-Type-Options header prevents browsers from interpreting files as a different MIME type than what is declared by the server. Without this header, browsers may perform MIME sniffing which could lead to security issues.

Business Impact:

Attackers may exploit this weakness to execute malicious scripts, potentially leading to data theft or unauthorized actions within the application.

5. Drupal API Vulnerability

CWE Number: CWE-20 – Improper Input Validation
OWASP Category: A03:2021 – Injection

Description:

Improper input validation in API requests may allow attackers to manipulate API parameters or inject malicious data. This can lead to unauthorized access or manipulation of application data.

Business Impact:

Attackers could exploit the vulnerability to access restricted resources, manipulate application behavior, or disrupt services.

6. Cross-Site Scripting (XSS)

CWE Number: CWE-79 – Improper Neutralization of Input During Web Page Generation
OWASP Category: A03:2021 – Injection

Description:

Cross-Site Scripting occurs when an application allows attackers to inject malicious scripts into web pages viewed by other users. The malicious code executes in the victim's browser.

Business Impact:

Attackers can steal session cookies, hijack user sessions, redirect users to malicious sites, or perform unauthorized actions on behalf of the victim.

7. Denial of Service (DoS)

CWE Number: CWE-400 – Uncontrolled Resource Consumption
OWASP Category: A04:2021 – Insecure Design

Description:

Denial of Service vulnerabilities occur when an attacker overwhelms

the application or server with excessive requests or resource consumption, causing the system to slow down or crash.

Business Impact:

Service disruptions can lead to financial losses, decreased productivity, and damage to the organization's reputation.

8. TLS 1.0 Detection

CWE Number: CWE-327 – Use of Broken or Risky Cryptographic Algorithm

OWASP Category: A02:2021 – Cryptographic Failures

Description:

TLS 1.0 is an outdated cryptographic protocol that contains known security weaknesses. Systems using TLS 1.0 are vulnerable to several cryptographic attacks.

Business Impact:

Attackers may exploit weaknesses in outdated protocols to decrypt sensitive communications or compromise secure connections.

9. web.config Disclosure

CWE Number: CWE-497 – Exposure of Sensitive System Information

OWASP Category: A05:2021 – Security Misconfiguration

Description:

The web.config file contains important configuration information such as database connection strings and application settings. If this file is publicly accessible, attackers may obtain sensitive information.

Business Impact:

Exposure of configuration files may reveal database credentials,

system paths, or other sensitive data that can be used to compromise the application.

10. Cross-Site Request Forgery (CSRF)

CWE Number: CWE-352 – Cross-Site Request Forgery

OWASP Category: A01:2021 – Broken Access Control

Description:

CSRF occurs when attackers trick authenticated users into performing unwanted actions on a web application without their knowledge.

Business Impact:

Attackers may perform actions such as changing account settings, transferring funds, or modifying sensitive data using the victim's authenticated session.

Stage 2

Overview

Tenable Nessus is a widely used vulnerability scanning tool developed by Tenable. It is a remote security scanner, which means that it does not need to be installed on the target system in order to perform a scan. Instead, Nessus scans systems by sending various probes and requests to the target host to identify potential vulnerabilities.

The scanner analyzes systems by generating network traffic, executing operating system checks, and sending application-level requests to detect security weaknesses. By analyzing the responses received from the target system, Nessus determines whether vulnerabilities exist.

Nessus uses a plugin-based architecture to detect vulnerabilities. Plugins are small pieces of code designed to identify specific security

issues. Thousands of plugins are available, covering vulnerabilities related to operating systems, web applications, databases, and network devices.

During a scan, Nessus first performs a discovery phase to identify the operating system, open ports, and services running on the target host. After identifying these components, it runs multiple vulnerability detection plugins to test for known security issues.

Once the scan is completed, Nessus generates a detailed vulnerability report. The report typically includes information such as the vulnerability name, severity level, plugin ID, affected ports, description of the issue, steps to reproduce the vulnerability, and recommended remediation measures.

These reports help security professionals identify risks in the system and take appropriate actions to improve overall security.

REPORT

1. Improper File Path Sanitization

Severity: Medium

Plugin: 35490

Port: 80 / 443

Description:

The web application does not properly validate file path inputs. This may allow attackers to manipulate file paths and access files outside the intended directory structure, leading to directory traversal attacks.

Solution:

Validate and sanitize user input used in file paths. Restrict file access to specific directories and implement secure file handling practices.

Business Impact:

Attackers may gain access to sensitive files such as configuration

files, system files, or application source code, potentially leading to system compromise.

2. Invalid SSL/TLS Certificate

Severity: Medium

Plugin: 51192

Port: 443

Description:

The SSL/TLS certificate presented by the server is invalid or improperly configured. This may allow attackers to intercept encrypted communications through man-in-the-middle attacks.

Solution:

Install a valid SSL/TLS certificate issued by a trusted Certificate Authority and ensure proper certificate configuration.

Business Impact:

Sensitive information such as credentials and personal data could be intercepted, leading to data breaches and loss of customer trust.

3. Missing X-Frame-Options Header

Severity: Low

Plugin: 98060

Port: 80 / 443

Description:

The web server does not send the X-Frame-Options header. Without this header, the website can be embedded in frames on malicious websites, which can enable clickjacking attacks.

Solution:

Configure the web server to include the X-Frame-Options header or implement a Content Security Policy (CSP) that prevents framing.

Business Impact:

Users may unknowingly perform actions such as clicking hidden buttons or submitting forms controlled by attackers.

4. Missing X-Content-Type-Options Header

Severity: Low

Plugin: 112529

Port: 80 / 443

Description:

The web server does not include the X-Content-Type-Options header. Without this header, browsers may perform MIME-type sniffing and interpret files differently than intended.

Solution:

Configure the web server to include the header X-Content-Type-Options: nosniff.

Business Impact:

Attackers may exploit this behavior to execute malicious scripts, potentially leading to cross-site scripting attacks.

5. Drupal API Vulnerability

Severity: Medium

Plugin: 118035

Port: 80 / 443

Description:

The Drupal API may contain improper input validation issues that allow attackers to manipulate API requests or inject malicious input.

Solution:

Update the Drupal platform to the latest secure version and ensure that API inputs are properly validated.

Business Impact:

Attackers may gain unauthorized access to application data or manipulate system functionality.

6. Cross-Site Scripting (XSS)

Severity: Medium

Plugin: 10815

Port: 80 / 443

Description:

The web application fails to properly sanitize user inputs before displaying them in web pages. This may allow attackers to inject malicious scripts that execute in users' browsers.

Solution:

Implement proper input validation, output encoding, and content security policies to prevent script injection.

Business Impact:

Attackers may steal session cookies, hijack user accounts, or redirect users to malicious websites.

7. Denial of Service (DoS)

Severity: Medium

Plugin: 11219

Port: 80

Description:

The server may be vulnerable to denial-of-service attacks due to improper resource handling or lack of request rate limiting.

Solution:

Implement rate limiting, resource monitoring, and network protections such as firewalls and load balancing.

Business Impact:

Attackers may overwhelm the server, causing service disruptions and downtime.

8. TLS 1.0 Detection

Severity: Medium

Plugin: 104743

Port: 443

Description:

The server supports TLS 1.0, which is considered outdated and contains known cryptographic weaknesses.

Solution:

Disable TLS 1.0 and enable stronger protocols such as TLS 1.2 or TLS 1.3.

Business Impact:

Weak encryption protocols may allow attackers to intercept or decrypt sensitive communications.

9. web.config Disclosure

Severity: Medium

Plugin: 121479

Port: 80 / 443

Description:

The web.config file is accessible via the web server. This file may contain sensitive configuration information such as database credentials.

Solution:

Restrict access to configuration files and ensure they cannot be accessed via HTTP requests.

Business Impact:

Attackers may obtain sensitive configuration data, potentially leading to system compromise.

Stage 3

Integration of Zscaler with Identity Providers (IdPs)

Overview

Modern organizations require secure access to cloud applications, corporate resources, and internet services. Traditional security models rely heavily on network boundaries, which are no longer effective due to remote work and cloud-based services.

Integrating Zscaler with identity providers such as Microsoft Entra ID (formerly Azure Active Directory) enables organizations to implement Zero Trust security architecture. In this model, every access request is verified based on user identity, device security status, and contextual information before granting access to applications.

This integration allows centralized authentication, single sign-on (SSO), and identity-based policy enforcement. It ensures that only authorized users and trusted devices can access corporate resources.

Identity

Identity verification is a key component of secure access control. By integrating Zscaler with Microsoft Entra ID, organizations can authenticate users using centralized identity management.

When a user attempts to access an application, the authentication request is redirected to the identity provider. The identity provider verifies the user's credentials and may require additional security measures such as multi-factor authentication.

Key identity-based controls include:

- **Single Sign-On (SSO) for seamless authentication**
- **Multi-Factor Authentication (MFA) for stronger security**
- **Role-based access control (RBAC)**
- **Identity-based policy enforcement**

These controls ensure that only verified users can access enterprise applications and services.

Device Posture

Device posture refers to the security condition of the device used to access corporate resources. Zscaler evaluates whether the device meets organizational security requirements before granting access.

Examples of device posture checks include:

- **Operating system version and patch level**
- **Antivirus or endpoint protection status**

- **Device compliance with security policies**
- **Device ownership (managed or unmanaged)**

If the device does not meet the required security standards, access may be restricted or limited. This helps prevent compromised or insecure devices from accessing sensitive resources.

Application Risk

Applications used within an organization may vary in their security levels and potential risks. Zscaler evaluates applications based on risk factors and security policies.

Application risk assessment may include:

- **Application reputation and trust level**
- **Data sensitivity handled by the application**
- **Potential vulnerabilities in the application**
- **Compliance with security standards**

Based on the risk level, Zscaler can apply different security policies such as restricting access, monitoring activity, or blocking access entirely.

Context-Aware Access

Context-aware access uses multiple factors to determine whether a user should be granted access to an application. Instead of relying only on usernames and passwords, the system considers additional contextual information.

These contextual factors include:

- **User identity**
- **Device security posture**

- **User location**
- **Time of access**
- **Application sensitivity**
- **Network security status**

By analyzing these factors, Zscaler can dynamically enforce security policies and reduce the risk of unauthorized access.

Conclusion

Integrating Zscaler with identity providers such as Microsoft Entra ID enhances organizational security by implementing identity-based access control. By combining identity verification, device posture assessment, application risk evaluation, and context-aware access policies, organizations can create a secure environment that supports modern cloud-based operations while protecting sensitive data.